QUIRRI B2B PLATFORM

Test Summary Report

Functional, integration, security, cross-browser, performance and infrastructure testing of the release candidate

Volume 1 of 3: Test Summary Report

Document	Test Summary Report (TSR), structured after ISO/IEC/IEEE 29119-3
Version	1.0, 9 November 2026
Test period	3 November 2026 (baseline) to 8 November 2026 (final regression)
System under test	Quirri B2B learning platform: web frontend (Next.js 15.5.29, React 19) and API (FastAPI, PostgreSQL 18)
Prepared by	Quirri Engineering, Quality Assurance
Prepared for	Client handover and acceptance
Companion volumes	Volume 2: Test Case Specification (every test case, by suite). Volume 3: Test Source Code Listing (the code of every test).
Status	Issued for review and sign-off

This document is confidential. It records the testing performed on the release candidate and is issued for client handover and acceptance. Results are reported as executed; nothing is reported from an earlier run unless it is labelled as a baseline.

Contents

1 Introduction . . . 5
1.1 Purpose . . . 5
1.2 Scope . . . 5
1.3 System under test . . . 5
1.4 References . . . 5
1.5 Deliverable set . . . 6

2 Executive summary . . . 6
2.1 Final results at a glance . . . 6
2.2 Key outcomes . . . 6
2.3 Release recommendation . . . 7

3 Test approach . . . 7
3.1 Test levels and types . . . 7
3.2 Principles applied . . . 8
3.3 Entry criteria . . . 8
3.4 Exit criteria and status . . . 8

4 Test environment . . . 8
4.1 Platform . . . 8
4.2 Tool versions . . . 9

5 Test execution timeline . . . 9

6 Test results . . . 10
6.1 Backend automated tests . . . 10
6.2 Integration suite on real PostgreSQL . . . 10
6.3 Frontend unit and infrastructure tests . . . 11
6.4 End-to-end cross-browser tests . . . 12
6.5 Accessibility . . . 12
6.6 Visual regression . . . 12
6.7 Performance and scalability . . . 13
6.8 Infrastructure, deployment and recovery . . . 13
6.9 Baseline for comparison (3 Nov 2026, cycle C0) . . . 14

7 Security testing . . . 14
7.1 Static analysis and supply chain . . . 14

7.2 Dynamic testing (DAST) . . . 14
7.3 Manual attack probes . . . 15
7.4 Upload and AI input attacks . . . 15

8 Defects found and resolved . . . 16
8.1 Security assessment findings (cycle C1) . . . 16
8.2 Production hardening and integration findings (cycles C2-C4) . . . 17
8.3 Remediation A: backend security (cycle C5) . . . 18
8.4 Remediation B: reliability and infrastructure (cycle C6) . . . 18
8.5 Remediation C: frontend (cycle C7) . . . 19

9 Known issues, deviations and residual risks . . . 19

10 Items not tested . . . 20

11 Owner actions before go-live . . . 20

12 Conclusion . . . 21

13 Sign-off . . . 21

Appendix A Test inventory by suite . . . 21

Appendix B How to re-run the tests . . . 22

Appendix C Evidence locations . . . 22

Document control

Version	Date	Change	Author
1.0	9 Nov 2026	First issue for client handover	Quirri QA

Approval. The sign-off table is in section 13. This report becomes the accepted test record once every role there has signed.

Terms used.

Term	Meaning
Test case	One test function (Python, pytest) or one *it/test* block (JavaScript). Volume 2 lists every one.
Execution	One run of a test case. A parameterised test case, or an E2E test run in six browser projects, counts once per run.
Integration (real SQL)	Tests that start the API in-process against a throwaway PostgreSQL database whose name ends in *_test*.
SAST / DAST	Static and dynamic application security testing.
Known failure	A failing test the owner has reviewed and accepted as not blocking release.
ID prefixes	AUTH, AUTHZ, APIX, SEC, SECA, SECB, INFRA, BACKEND, PERF, DATA, XB, QA, FE: issue identifiers in the project issue register.

1 Introduction

1.1 Purpose

This report records the testing of the Quirri B2B platform release candidate before production deployment. It states what was tested and how, what was found and fixed, and the result of the final regression. It also states what was not tested and the conditions the owner must meet before go-live. It is the summary volume of a three-volume test deliverable.

1.2 Scope

In scope	Out of scope
• Backend API: authentication, authorisation, multi-tenant isolation, all routers • Content pipeline: video jobs, quizzes (MCQ), voice tutor (logic only) • Frontend: five role portals (Super Admin, College Admin, HOD, Faculty, Student) • Security: SAST, dependency and image scanning, DAST, manual attack probes • Cross-browser and tablet E2E, accessibility scans, visual comparison • Performance of reports at 30,000 students; multi-worker operation • Container images, compose files, nginx, backup and restore, migrations	• Production systems and production data (never accessed) • Paid AI, text-to-speech and voice provider calls (stubbed or not run) • Real e-mail delivery (log provider used) • Voice over restricted college networks (needs a TURN server) • User acceptance testing by real users • Legal compliance review (DPDP consent and retention) • GitHub-hosted CI runs of the changed workflows

1.3 System under test

Frontend	Next.js 15.5.29, React 19.2, App Router. Repository *b2b_superAdmin_frontend*, branch *main_backup_working*.
Backend	FastAPI on uvicorn, SQLAlchemy, Alembic head **0057**. Repository *b2b_projectk*, branch *arun_master_24082026*.
Database	PostgreSQL 18
Build tested	The working trees of both repositories as of 8 November 2026. The changes are not yet committed. After commit, the commit hashes should be added here so this report points at a fixed build.
Roles	Super Admin (platform), College Admin, HOD, Faculty, Student (each bound to one college)

1.4 References

- ISO/IEC/IEEE 29119-3: Software testing, test documentation (structure of this deliverable)
- OWASP Application Security Verification Standard 4.0 and Web Security Testing Guide (security test design)
- OWASP API Security Top 10 (2023): BOLA, BFLA, mass assignment, resource consumption
- WCAG 2.1 level AA (automated axe-core checks)
- Project issue register (*docs/audit/ISSUE_REGISTER.md*) and evidence folders (*docs/audit/evidence/*)

1.5 Deliverable set

Volume	Content	Use
1. Test Summary Report	Approach, environment, results, defects, risks, owner actions, sign-off	Decision to release
2. Test Case Specification	Every test case with its ID, suite, file, line, run count and result, segregated by suite	Traceability and audit
3. Test Source Code Listing	Full source of every test file, fixture and probe script, one file per section	Review and re-execution

2 Executive summary

The final regression on 8 November 2026 ran every automated suite against the release candidate. **No security or functional test fails.** The only failures are two video-slide layout tests (text spacing), which fail the same way before these changes and which the owner reviewed and accepted. All Critical and High findings from the security assessment are fixed and re-tested, except those that need an owner action outside the code (secret rotation and configuration). Those are listed in section 11.

2.1 Final results at a glance

Suite	Executed	Passed	Failed	Skipped	Result
Backend: unit, API, security, pipeline (pytest)	2,810	2,798	2	10	Pass (2 known failures)
of which: integration on real PostgreSQL	1,286	1,284	0	2	Pass
Frontend unit and infrastructure (vitest)	405	405	0	0	Pass
End-to-end, 6 browser projects (Playwright)	1,512	1,512	0	0	Pass
Visual comparison, 12 full-page screenshots	12	12	0	0	Pass (0.000% difference)
Frontend lint (ESLint)	1	1	0	0	Pass (0 errors, 8 warnings)
Dependency audit (npm, full)	1	1	0	0	Pass (0 vulnerabilities)
Manual attack probes (6 Nov assessment)	49	44	0	0	Pass, 3 fixed, 2 observations

The integration row is part of the backend row, not in addition to it. Probe outcomes: 44 passed on the day. HDR-01, HDR-02 and DOS-02 were defects and are fixed (section 7.3). RL-02 and DOS-01 were observations.

2.2 Key outcomes

- **Security.** The assessment covered SAST (semgrep, bandit), dependency and image scans (pip-audit, npm audit, Trivy), secret scanning (gitleaks) and DAST: OWASP ZAP with 5 roles, and Schemathesis with about 117,000 generated API cases. 49 manual attack probes were also run. Findings were fixed, each with a regression test. After the fixes the Schemathesis run gives 0 server errors.
- **Tenant isolation.** A real-SQL tenant isolation matrix (360 test executions) and list-scope suite (267) prove no role can read or change another college's data.
- **Framework upgrade.** Next.js 14 to 15.5.29 and React 19 removed the remaining critical framework advisory, with no visual change.
- **Production hardening.** The added controls are: a nonce-based Content-Security-Policy, request-size limits, upload attack protection (XXE, billion laughs, zip bombs), an AI prompt-injection boundary, AI call timeouts, non-root containers, a durable e-mail outbox, and multi-worker operation.

- **Browsers.** Every E2E project is green, including WebKit (previously 5 failures) and the tablet projects. One genuine tablet navigation bug (XB-013) was found and fixed.
- **Performance.** At 30,000 students, the college dashboard report fell from 10.8 s to 0.98 s and the department report from 12.7 s to 1.0 s.

2.3 Release recommendation

Recommended for release, conditional on the owner actions in section 11. The code-level exit criteria (section 3.4) are met. Release must not proceed until these are done: the secrets in git history are rotated, bootstrap is disabled in production, the production configuration values are set, and user acceptance testing is complete.

3 Test approach

3.1 Test levels and types

Level / type	Technique	Tool	Where it is recorded
Unit	Function and component tests with stubs; no network	pytest, vitest	Vol 2: BE-API, BE-VID, BE-MCQ, BE-VOI, FE-UNIT
API / integration	In-process API against a throwaway PostgreSQL database; real SQL, real login cookies; any non-loopback network connection fails the test	pytest + FastAPI TestClient	Vol 2: BE-INT
Authorisation and tenant isolation	Matrix of roles x routes x two colleges; list-scope and write checks	pytest	BE-INT (tenant matrix, list scope, RBAC)
Security: static	SAST rulesets, dependency CVEs, image CVEs, secrets in history, workflow lint	semgrep, bandit, pip-audit, npm audit, Trivy, gitleaks, actionlint	Section 7.1
Security: dynamic	Authenticated active scanning and schema-driven fuzzing per role	OWASP ZAP, Schemathesis	Section 7.2
Security: manual	Scripted attack probes (OWASP API Top 10, JWT, CORS, enumeration, injection, DoS)	Python probes	Section 7.3; Vol 2 SEC-PRB; Vol 3
End-to-end	Role journeys through the real UI and API	Playwright: Chromium, Firefox, WebKit, Edge, 2 tablet	Vol 2: FE-E2E
Accessibility	axe-core scans inside the E2E journeys	axe-core (Playwright)	FE-E2E a11y specs
Visual regression	Full-page screenshots, pixel difference	Playwright + image diff	Section 6.6
Performance	Timed report queries on a 30,000-student data set; 4-worker live check	pytest, scripted timing	Section 6.7
Infrastructure	Image builds and scans, compose validation, nginx -t, backup and restore drill, migration round trip	Docker, Trivy, nginx, Alembic	Section 6.8
Configuration	Static checks of next.config, Dockerfiles, workflows, env examples	vitest (infra), pytest	FE-INFRA; BE-API

3.2 Principles applied

- Each defect fix carries a regression test that fails before the fix and passes after it.
- Assertions were never relaxed to make a test pass. Where a time limit was raised, this report says so (section 9).
- Tests ran on throwaway databases only. Each database name ends in *_test*, and the test harness refuses any other name.
- No production system was used and no paid provider was called. AI, text-to-speech and voice clients were replaced by fakes.
- Credentials are read from environment variables. None is stored in test code; Volume 3 was checked for this before issue.

3.3 Entry criteria

- Both repositories build; database migrations reach a single head.
- A seeded test data set exists with two colleges and every role.
- Ports and databases used by the owner's development environment are excluded from testing.

3.4 Exit criteria and status

Criterion	Status
No open Critical or High defect in code	**Met**
Every fixed defect has a passing regression test	**Met**
Backend and frontend suites pass, except failures the owner reviewed and accepted	**Met (2 known failures)**
E2E suite green on all supported browsers	**Met (6 of 6 projects)**
No unexplained skipped test	**Met (10 skips, each explained in section 6.1)**
Owner actions for go-live identified	**Met (section 11)**
User acceptance testing complete	**Open: owner and client**

4 Test environment

4.1 Platform

Host	Windows 11 with WSL 2 (Linux), Docker in WSL
Database	PostgreSQL 18 in WSL. Each test stream had its own throwaway database, for example *quirri_integ_test*, *quirri_secfix_test*, *quirri_relfix_test*, *quirri_fefix_test*, *quirri_final_test*
API under test	uvicorn on 127.0.0.1, on dedicated ports 8501, 8601, 8711, 8712 and 8713 (never the development port 8000). Started without auto-reload.
Frontend under test	Production build served by *next start* on dedicated ports 3501, 3601, 3713 and 3714 (never the development port 3000). Each build used its own output folder.
Isolation	The frontend remediation ran in a separate copy of the repository. The 41 changed files were copied back byte for byte and verified identical.
Data	Two seeded colleges with every role; additional generated data for performance (30,000 students) and backup (5,000 rows).
External services	E-mail provider = log; AI, text-to-speech and voice providers stubbed; dummy provider keys during DAST.

4.2 Tool versions

Tool	Version	Tool	Version
Python / pytest	3.12.13 / 9.1.1	Node.js / npm	22 / 10 (CI image); 26.3 / 11.16 (local)
vitest	5.1.0	Playwright / axe-core	1.64.1 / 4.12.1
Next.js / React	15.5.29 / 19.2	ESLint	8.57.1 (CLI)
semgrep	1.184.0	bandit	1.9.4
pip-audit	2.10.1	Trivy	0.76.2
gitleaks	8.21.2	actionlint	1.7.8
OWASP ZAP	zap-stable (Docker)	Schemathesis	4.33.1
nginx (config test)	1.27-alpine	PostgreSQL	18

5 Test execution timeline

Testing ran in cycles. Each cycle's findings were fixed before the next cycle began, and the final cycle re-ran everything together.

Cycle	Date	Activity	Outcome
C0 Baseline	3 Nov	Phase 4 audit: full backend, frontend and E2E suites, load test, static and dependency checks	Baseline recorded (section 6.9)
C1 Security assessment	6 Nov	SAST and supply chain; DAST (ZAP, Schemathesis) with 5 roles; 49 manual attack probes	SECA-001..018 and SECB-001..012 raised; Critical/High fixed the same day
C2 Production hardening	6-7 Nov	PyJWT replaces python-jose; non-root backend container; seed secret from environment; proxy trust	Hardening tests added (tests/test_prod_hardening.py)
C3 Framework upgrade	6 Nov	Next.js 15.5.29 and React 19; full E2E on 3 browsers; visual comparison	1 critical advisory removed; WebKit improved; 0.2% visual difference
C4 Integration suite	6-7 Nov	Real-SQL suite built: tenant matrix, list scope, RBAC and sessions, privacy, API abuse, exports	1,228 passed; 4 defects found and fixed
C5 Remediation A	7-8 Nov	Backend security: deactivation, body limits, uploads, prompt boundary, timeouts, OpenAPI contract	10 items fixed; integration 1,264 passed
C6 Remediation B	7-8 Nov	Backend reliability and infrastructure: reports at scale, e-mail outbox, workers, images, backups, nginx	12 items fixed; full backend 2,798 passed
C7 Remediation C	7-8 Nov	Frontend: nonce CSP, CORP, vitest 5, image, ESLint CLI, flaky E2E root causes, Unpublish	All 6 E2E projects green; 405 unit tests
C8 Final regression	8 Nov	Full backend suite with all changes together; frontend unit, lint, infra and audit; source match check	Section 6

6 Test results

6.1 Backend automated tests

Suite ID	Area	Files	Test cases	Executions	Failed	Skipped
BE-API	Unit, API, configuration and security	22	255	409	0	8
BE-INT	Integration on real PostgreSQL	11	105	1,286	0	2
BE-VID	Video pipeline (edu_video)	37	499	602	2	0
BE-MCQ	Quiz (MCQ)	7	89	156	0	0
BE-VOI	Voice tutor (voice_qna)	11	214	357	0	0
Total		**88**	**1,162**	**2,810**	**2**	**10**

Final run: 8 Nov 2026, the whole *tests/* tree in one process: **2,798 passed, 2 failed, 10 skipped** in 16 min 38 s. The run used Alembic head 0057, the new uharfbuzz dependency and the throwaway database *quirri_final_test*. The failure and skip breakdown above was confirmed by a targeted rerun.

Failed tests (known, accepted)

Test	Reason	Disposition
`tests/edu_video/test_diagram_wave_layouts.py::test_wave_labels_never_overlap_and_are_all_readable[6]`	Slide text spacing on one diagram layout variant	Fails identically before the changes; reproduced with Pillow 12.3. Owner accepted as not security-related.
`tests/edu_video/test_layout_and_source.py::test_list_layout_shrinks_instead_of_dropping_or_overflowing`	List slide text spacing	Same as above

Skipped tests (all explained)

Test location	Count	Reason
`tests/test_teaching_portal_routers.py`	8	Interview routers are switched off by design (INTERVIEWS_ENABLED=false; the module was removed on 20 Oct 2026). On 3 Nov these 8 passed with the flag on.
`tests/integration/test_api_abuse.py:59`	1	One parameter value (offset=0) is the first page, so the overflow case does not apply.
`tests/integration/test_api_abuse.py:382`	1	The test environment uses the development JWT placeholder; the production-secret check applies only with a real secret.

6.2 Integration suite on real PostgreSQL

The integration suite starts the API in-process against a throwaway PostgreSQL database with two seeded colleges and every role. It signs in with real cookies and asserts both the HTTP status and what data came back. Passing tests grew from 1,228 (cycle C4) to 1,264 (C5) and 1,284 of 1,286 executions in the final run (2 skips, section 6.1).

Module	Test cases	Executions	What it proves
`test_api_abuse.py`	17	227	Hostile paging values, NUL bytes, formula payloads and rotating proxy headers get a clean 4xx, never a 5xx or a bypass
`test_authz_default_permissions.py`	4	5	AUTHZ-006: an empty permission list falls back to the role defaults; an explicit list still restricts

Module	Test cases	Executions	What it proves
test_institution_access.py	4	5	AUTH-006: a deactivated college or university locks out its users on every stack; reactivation restores the same sessions
test_list_scope.py	14	267	Lists, summaries and exports never show another college; a filter can never widen the caller's scope
test_privacy.py	13	43	No response carries a password, hash or token; the login answer carries no token; e-mail bodies and audit secrets are never returned
test_rbac_and_sessions.py	20	325	401 without a session and 403 for every lower role; no self-escalation of role, permissions or college; deactivated, logged-out and revoked tokens refused
test_reliability_fixes.py	17	20	BACKEND-028, BACKEND-021, BACKEND-031, PERF-006 and related fixes: SQL aggregates, delete guard, durable outbox, leader lock
test_search_wildcards.py	3	26	% and _ in search text are matched literally, not as wildcards
test_sec_attack_exports.py	3	3	SECC-001: CSV/XLSX formula injection is neutralised in report and audit-log exports
test_tenant_isolation_matrix.py	9	360	TEST-001: every role of college A against college B's objects is refused (403/404), never 2xx or 5xx, and nothing of college B appears in the body
test_upload_attacks.py	1	5	INFRA-018 through the real upload route: XXE, billion laughs, zip bombs and renamed files refused before any job is recorded

Defects the integration suite found and fixed in cycle C4:

- College roles (College Admin, HOD, Faculty, Student) with no college assigned were treated as "no filter" and could see every college's data. They are now refused with 403 "Tenant context required", in the async and sync dependencies.
- The pending-changes list for staff was not limited to their own scope (edu_video bridge). It is now scoped.
- The staff subjects route revealed other colleges' staff names. It now returns 404 without the name.
- Validation errors on auth routes echoed the submitted input, including passwords. The input and context fields are now stripped from 422 responses.
- AUTHZ-006: users with an empty permission list were refused routes their role allows. They now inherit the role defaults (5 tests).

6.3 Frontend unit and infrastructure tests

Suite	Files	Tests	Passed	Result
FE-UNIT: components, API clients, helpers	38	373	373	Pass
FE-INFRA: next.config, Dockerfile, workflows, lockfile, env and security headers	1	32	32	Pass
Total (vitest 5.1.0)	**39**	**405**	**405**	Pass

Progression: 384 tests on 6 Nov (Next 14) to 385 after the Next 15 upgrade, and 405 after remediation C. ESLint (CLI, same rules): 0 errors, 8 warnings, all react-hooks dependency warnings that predate this work. *npm audit* (all dependencies including development): 0 vulnerabilities.

6.4 End-to-end cross-browser tests

352 tests in 11 spec files cover the five role portals: sign-in, navigation, the College Admin and Super Admin journeys, notifications, settings, scoping, resilience, browser APIs and accessibility. The tablet projects run the 52 layout-sensitive tests. Every page also fails a test if the browser reports a Content-Security-Policy violation.

Project	Next 14 baseline (6 Nov)	After Next 15 (6 Nov)	Final (8 Nov)	Result
Chromium (desktop)	320 passed / 1 failed	352 / 0	352 / 0	Pass
Firefox (desktop)	352 / 0	352 / 0	352 / 0	Pass
WebKit (desktop)	306 / 5	337 / 2	352 / 0	Pass
Microsoft Edge	not run	not run	352 / 0	Pass
Chromium tablet	not run	not run	52 / 0	Pass
WebKit tablet	not run	not run	52 / 0	Pass
Total			**1,512 / 0**	Pass

Final totals combine full run 3 with a rerun of the three specs changed after it (a11y, college-admin, resilience), which passed on all six projects. A first full run was discarded because the host went to sleep during the WebKit leg; everything was re-run with the host kept awake.

Flaky and failing E2E tests: root causes fixed

ID	Symptom	Root cause	Fix
XB-013	Tablet menu taps closed the menu instead of navigating	Genuine bug: for Super Admin, College Admin and Faculty at 1023 px and below, the open drawer sat under its dark overlay	One CSS rule in portal-b2c.css, matching the student portal; helper waits for the slide
QA-FLAKE-003	Dropdown clicks lost in WebKit	QuirriCombobox and QuirriSelect scrolled the dialog under the open menu	Scroll only the option list
QA-FLAKE-003	Seat-cap and invite tests timed out	A second page sent the test page to the background, where WebKit slows clicks to about 11 s	Super Admin signs in through the API, with no second page
(dept)	Department created twice on double-click	Genuine bug: the create drawer accepted a second submit while saving	Submit ignored while saving; the row ignores a second click
(waits)	Intermittent timing failures	Tests acted before the portal finished loading	settled() waits for the loading placeholder; a11y retries until the fade-in ends

6.5 Accessibility

axe-core scans run inside the E2E accessibility journeys for every signed-in role, at 1440 px and 390 px. In the final run they pass on all six browser projects. The 3 Nov baseline had recorded 60 brand-colour contrast violations, held for an owner decision (UX-002, UX-003). Those specs now pass.

6.6 Visual regression

Twelve full-page screenshots (the login page, plus the five role dashboards at 1440 px and 390 px) were taken from the final build and from a build of the source before remediation C, on the same database at the same time. **All 12 differ by 0.000%.** Against the Next 15 reference images, the login page is 0.000% and the dashboards differ by 0.1-6.4%, from changed data only (more journey colleges, more review counts). The login page is a frozen design and is unchanged.

6.7 Performance and scalability

Report generation was timed on a scratch database seeded with 30,000 students, before and after BACKEND-028. BACKEND-028 moved student filtering and completion counting into SQL and passes long id lists as one array parameter:

Report	Before	After	Change
Institution (Super Admin dashboard)	10.8 s	0.98 s	11 x faster
Department	12.7 s	1.0 s	12.7 x faster; rows identical before and after
Student (30,000 rows)	12.0 s	9.1 s	Still dominated by building 30,000 rows in Python (section 9)

Correctness at scale: a copy of the old algorithm checks the new numbers in 4 range and subject cases. Group totals equal the sum of their students. A list of 40,000 ids is accepted, beyond PostgreSQL's 32,767 bind-parameter limit.

Multi-worker operation (PERF-006)

- Production runs 4 uvicorn workers (WEB_CONCURRENCY, default 4). Connection pools are sized to 60 of PostgreSQL's 100 connections.
- The rate limiter is shared through Redis. Periodic jobs (health row, pruning, ingestion reconciliation, job recovery) run in one worker at a time under a PostgreSQL advisory lock. Queues use FOR UPDATE SKIP LOCKED.
- Live check with 4 workers: health 200, 4 outbox drains started, 3 health rows in about 2.5 minutes (one per minute, as designed), 24 database connections, no errors.

6.8 Infrastructure, deployment and recovery

Check	Result
Backend image (multi-stage, non-root uid 10001)	**Pass**: starts offline under --read-only; /app/media writable; no compiler in the image; 4.13 GB to 2.92 GB
Backend image scan (Trivy)	**Residual**: 1 Critical (libxml2 CVE-2026-6653) and 229 High in OS packages, none with a fixed version available yet. One Python High is a false positive (pip's vendored list)
Frontend image (runs node directly, no npm in runtime)	**Pass**: /auth/login 200, health 'healthy', user node, no package managers on PATH
Frontend image scan (Trivy)	**Pass**: 0 High/Critical; 1 Medium (zlib CVE-2026-4738, Alpine base)
Compose files (no-new-privileges, read_only, healthchecks, LiveKit pinned v1.13.11)	**Pass**: docker compose config validates
nginx production config	**Pass**: nginx -t in nginx:1.27-alpine; HTTPS only, HSTS, TLS 1.2/1.3, X-Forwarded-For overwritten, body limits 2m / 55m
Backup and restore drill (database + media, checksums)	**Pass**: 5,000 rows dumped and restored to a second database; row counts match on all 46 tables; refusal cases work
Migrations	**Pass**: single head 0057; upgrade head, downgrade to 0044, upgrade head on a scratch database
npm ci with the committed lockfile	**Fixed**: failed under npm 10 ('Missing: react-is@16.13.1'), so CI and the Docker build would have failed. Regenerated; npm 10 and 11 accept it

6.9 Baseline for comparison (3 Nov 2026, cycle C0)

Recorded before this engagement's fixes, on a single uvicorn worker on the QA stack, for comparison:

Suite (3 Nov)	Result
Backend unit + API + auth + database	1,539 executed: 1,531 passed, 8 skipped (interview routers; 14/14 with the flag on)
Frontend unit	294 / 294
E2E, all roles, 1440 and 390	252 executed: 192 passed, 60 blocked on the brand-colour contrast decision
Dependencies	npm (production) 1 critical, 2 high; backend 1 advisory
Load, 20 concurrent, 15 s per route	0 errors; p95 372-1,231 ms; slowest GET /dashboard (Super Admin) p95 1,231 ms

7 Security testing

The owner authorised the assessment, which ran on 6 November 2026 on local throwaway stacks only. Every paid provider key was a dummy. No token, password or secret is stored in the evidence folders.

7.1 Static analysis and supply chain

Tool	Before	After fixes
semgrep, backend	24 (2 ERROR, 22 WARNING)	16, all triaged as false positives or intended (action pins and SHA-1 fixed)
semgrep, frontend	10 WARNING (mutable action tags)	0
bandit, backend	1 High (B324), 38 Low	0 High; 38 Low (best-effort cleanup, non-crypto random, fixed-argv subprocess)
pip-audit, lock file	72 advisories in 11 packages	4, then python-jose and ecdsa removed with PyJWT (SECA-009); opentelemetry-api blocked upstream
npm audit (production)	2 (next critical, postcss high)	0 after the Next 15 upgrade
npm audit (full, including dev)	17	0 after vitest 5 and the minimatch override
gitleaks, git history	backend 7, frontend 2 (all previously known)	Unchanged: needs owner key rotation (section 11)
actionlint	SC2034 only (unused loop variable)	No security finding

7.2 Dynamic testing (DAST)

- **Coverage.** OpenAPI 138 operations on 115 paths. Schemathesis ran as each of the 5 roles on 128 operations, plus the 10 session operations unauthenticated. Phases: examples, coverage, fuzzing and stateful. Cases: 84,704 before the fixes, 107,565 after, and 9,205 in a targeted pass on the 13 operations that had failed.
- **Server errors.** Before the fixes: 21 failing cases and 152 HTTP 5xx (148 x 503, 4 x 500). **After: 0 server errors and 0 HTTP 5xx across about 117,000 cases.**
- **OWASP ZAP.** Ran an API active scan with each role's session, a frontend full scan with the AJAX spider as College Admin and as Student, and passive baselines before and after the fixes. Every High alert was replayed and is a false positive: a typed UUID, the rate limiter's 429, or validation-message differences.
- **Production mode.** With ENVIRONMENT=production, the OpenAPI document and the docs pages return 404. Auth cookies are HttpOnly, Secure and SameSite=Strict. Error bodies contain no stack traces, and TRACE returns 405.

7.3 Manual attack probes

Category	Probes	Passed	Outcome
Access control: BOLA / IDOR across colleges	10	10	Every cross-tenant read gives 403 or 404
Access control: BFLA (function level)	8	8	Lower roles refused admin functions (403)
Mass assignment	3	3	Role, college and permissions cannot be set by the caller
JWT and sessions	12	12	alg=none, forged, stripped, alg confusion, kid injection, expired, nbf, wrong type, reuse after logout and password change, refresh replay: all refused
CORS and cookies	3	3	No origin reflection; HttpOnly + SameSite=Strict
Enumeration and brute force	4	3	Identical login and reset answers; IP rotation still throttled. RL-02 observation below
Injection (SQL)	3	3	Search, sort and audit filters parameterised
Resource consumption	2	0	DOS-01 observation; DOS-02 fixed by APIX-006
Information disclosure	4	2	Docs gated, no stack traces; HDR-01 and HDR-02 fixed
Total	**49**	**44**	

Probe results that did not pass on the day

Probe	Finding on 6 Nov	Status now
HDR-01	API responses had no X-Frame-Options, CSP, nosniff, HSTS or Referrer-Policy	**Fixed** (SECB-001): security headers middleware; ZAP Low 2 to 0
HDR-02	Server: uvicorn header disclosed	**Fixed** (SECB-002): --no-server-header
DOS-02	2,000-level nested JSON returned 500; no body-size cap	**Fixed** (APIX-006): 1 MB cap (52 MB on upload routes), 413 before reading; nesting deeper than 64 gives 400
DOS-01	Paging bounds enforced on reports (422); the probing role could not reach the users route (403)	**Observation**: SECB-004 then bounded page and offset on every list route
RL-02	12 login attempts with e-mail case and whitespace variants gave 401, no 429	**Observation**: the per-account limiter lower-cases the e-mail; re-test recommended (section 9)

7.4 Upload and AI input attacks

- XXE, billion-laughs, zip-bomb, compression-ratio bomb, too-many-entries and renamed-executable payloads went through the upload check, the video extractor, the quiz parser, the voice parser and the real POST /edu_video/upload route. Each one gets 400. No file content leaks and no job is created.
- Limits: 100 MB unpacked, 5,000 archive entries, 200x ratio for parts over 1 MB, 1,000 pages or slides. Any DOCTYPE or ENTITY declaration is refused, including UTF-16 and padded prologs. The file type is decided by magic bytes, not the extension.
- Prompt injection (INFRA-031): uploaded document text sits inside an untrusted-data boundary. The text cannot close the boundary, including with full-width look-alike and zero-width characters. Tests use fake AI clients only.
- Timeouts (INFRA-019): every AI client in the video, quiz and voice modules has a timeout. An AST scan in the test suite enforces this.

8 Defects found and resolved

Every item below is fixed in the build under test and covered by a passing regression test unless the status says otherwise. Volume 2 lists each verifying test case.

8.1 Security assessment findings (cycle C1)

ID	Sev.	Defect	Resolution	Status
SECA-001	Low	SHA-1 fingerprint not marked as non-security (bandit B324)	Marked usedforsecurity=False	Fixed
SECA-002	High	Lock file pinned vulnerable aiohttp, certifi, pillow, urllib3 and others	Lock updated; pip-audit 72 to 4	Fixed
SECA-003	Critical	Next.js image optimiser RCE/DoS advisories	Optimiser off (404); then Next 15 upgrade	Fixed
SECA-004	Medium	17 workflow actions on mutable tags	Pinned to commit SHA	Fixed
SECA-005	Low	Frontend image shipped development dependencies	npm prune --omit=dev	Fixed
SECA-006/007	High/Low	postcss 8.4.31, svgo, eslint-config-next advisories	Overrides and upgrades	Fixed
SECA-008	Medium	Backend container ran as root	uid 10001; deploy chowns the media volume	Fixed
SECA-009	Low	python-jose and ecdsa advisories with no fix	Replaced by PyJWT 2.15.0	Fixed
SECA-010	Low	opentelemetry-api advisory (QA-004)	Waiting for an upstream release	Open: upstream
SECA-011	High	Keys and seed password in git history	Code side done (seed from environment); rotation is an owner action	Open: owner
SECA-012	Critical	Remaining Next 14.2.35 advisories	Next 15.5.29 + React 19	Fixed
SECA-013	Low	vitest 2 chain advisories (dev)	vitest 5.1.0; minimatch override	Fixed
SECA-014	Low	Compose hardening; livekit:latest	no-new-privileges, read_only, healthchecks, v1.13.11	Fixed
SECA-015	Info	Sign-in tokens in local .playwright-mcp logs	33 log files deleted	Fixed
SECA-016	Info	Dead code executed AI-generated Python	Deleted; test asserts no manim CLI use	Fixed
SECA-017	Low	Old setuptools; build tools in runtime image	Multi-stage image; setuptools 84.2.1	Fixed
SECA-018	Low	npm in frontend runtime image	CMD runs node; package managers removed	Fixed
SECB-001	Medium	API security headers missing	Pure ASGI headers middleware; HSTS outside dev	Fixed
SECB-002	Low	Server header disclosed	--no-server-header	Fixed
SECB-003	Low	No Cross-Origin-Opener-Policy	COOP same-origin	Fixed
SECB-004	Medium	Unbounded page/offset gave 503 and false outage records	422 for invalid input; real outages still 503	Fixed

ID	Sev.	Defect	Resolution	Status
SECB-005	Medium	NUL byte in text gave 503/500	422 on both database drivers	Fixed
SECB-006	Low	Voice history offset past int64 gave 500	Offset bounded	Fixed
SECB-007	Info	OpenAPI contract did not match real errors and file types	Error schema, status codes and media types documented	Fixed
SECB-008	Low	Bootstrap route mounted in production	Mounted only locally with ENABLE_BOOTSTRAP	Fixed
SECB-009	Medium	Frontend CSP allowed inline scripts and any https/wss origin	Per-request nonce CSP, strict-dynamic; origins pinned	Fixed
SECB-010	Low	No Cross-Origin-Resource-Policy	CORP same-origin	Fixed
SECB-011/012	Info	Profile in sessionStorage; long cache on page shells	Reviewed: no tokens or user data	Accepted

8.2 Production hardening and integration findings (cycles C2-C4)

ID	Sev.	Defect	Resolution	Status
AUTHZ-006	High	Users with empty permissions refused their role's routes	Fall back to role defaults; explicit list still restricts	Fixed
(tenant)	High	College role with no college saw all colleges' data	403 Tenant context required	Fixed
(scope)	Medium	Staff pending-changes list not scoped	Scoped to staff	Fixed
(names)	Low	Staff subjects route leaked other colleges' staff names	404 without the name	Fixed
(echo)	Medium	422 on auth routes echoed submitted input, including passwords	input/ctx stripped	Fixed
AUTH-009	High	Seed password hard-coded	Read from SEED_SUPERADMIN_PASSWORD (minimum 12 characters); rotation is an owner action	Fixed (code)
(proxy)	Medium	Proxy trust implicit, so all users could share one rate-limit address	--forwarded-allow-ips 127.0.0.1 in image and compose	Fixed

8.3 Remediation A: backend security (cycle C5)

ID	Sev.	Defect	Resolution	Status
AUTH-006	High	Deactivated college or university kept its users signed in	Live check on every request (cookie, Bearer, voice); login, refresh and activation refused	Fixed
APIX-006	Medium	No request body limit; deep JSON gave 500	1 MB cap, 52 MB on upload routes, streaming count, nesting depth 64	Fixed
(LIKE)	Low	% and _ in search acted as wildcards	Escaped in 10 routers and services	Fixed
INFRA-018	High	Upload parsing open to XXE, entity expansion and zip bombs	Magic-byte typing, archive limits, DOCTYPE refusal, re-check before parsing	Fixed
INFRA-031	Medium	Document text could steer AI prompts	Untrusted-data boundary that cannot be closed	Fixed
INFRA-019	Medium	AI provider calls had no timeouts	Timeouts and bounded retries on every client	Fixed
INFRA-023	Medium	DEBUG could be switched on in production	Forced off outside local/dev/test	Fixed
INFRA-029	Medium	Test e-mail redirect could apply in production	Cleared in production; refused at runtime	Fixed

8.4 Remediation B: reliability and infrastructure (cycle C6)

ID	Sev.	Defect	Resolution	Status
BACKEND-028	High	Reports loaded every student into memory	SQL subqueries and aggregates; array parameter for id lists	Fixed
BACKEND-031	High	Bulk e-mails lost on restart	Durable outbox (migration 0057), lease, retry with backoff, de-duplication	Fixed
PERF-006	Medium	Single API worker	4 workers; shared limiter; leader lock for periodic jobs	Fixed
BACKEND-021	Medium	Published chapter could be deleted	409 until unpublished; new unpublish endpoint and UI	Fixed
BACKEND-026	Medium	Tamil text printed incorrectly in PDFs	Noto Sans Tamil with HarfBuzz shaping	Fixed
INFRA-007	High	Backups covered the database only; no restore drill	Database + media with checksums; restore script; drill passed	Fixed
INFRA-008	Medium	nginx configuration incomplete	Complete config; nginx -t passes	Fixed
INFRA-021	Medium	No external alerting	Optional webhook alerts, de-duplicated across workers	Fixed
DATA-021	Low	Migration 0029 downgrade could fail half-way	Refuses with a clear message	Fixed
BACKEND-002 BACKEND-053	Low	Migration head and documentation drift	Single head 0057; docstrings corrected	Fixed

8.5 Remediation C: frontend (cycle C7)

ID	Sev.	Defect	Resolution	Status
XB-013	Medium	Tablet menu unusable for three roles	CSS stacking fix	Fixed
QA-FLAKE-003	Low	WebKit dropdown and timeout flakes	Component scroll fix; test harness fixes	Fixed
(dept)	Medium	Department created twice on double-click	Submit guarded while saving	Fixed
INFRA-025 / FE-028	Medium	Test-server IP and old domain in the frontend; development bypass flag	Removed; infra test guards against return	Fixed
(lockfile)	High	npm ci failed under npm 10	Lockfile regenerated	Fixed
(lint)	Low	next lint removed in Next 16	ESLint CLI, same rules	Fixed

9 Known issues, deviations and residual risks

#	Item	Impact	Recommendation
KI-01	2 video-layout tests fail (section 6.1)	Slide text spacing only	Fix in a later release
KI-02	Student report takes 9.1 s at 30,000 students	Slow for the largest colleges	Paginate rows in SQL
KI-03	Backend image: 1 Critical, 229 High OS CVEs with no fix available yet	Patched when Debian releases fixes	Rebuild the image regularly; rescan with Trivy
KI-04	RL-02: e-mail variant throttling not re-tested after remediation	Possible weaker per-account throttle	Re-run probe RL-02 against the final build
KI-05	WebKit long form journeys marked test.slow() (3 x time limit)	WebKit took 2-5 s per action on the test host	Re-check on a faster CI runner
KI-06	@playwright/test remains in the frontend runtime node_modules	Larger image; test tool shipped	Move to devDependencies
KI-07	Interview resume parser has no zip-bomb guard	Module off by default; body cap still applies	Add the guard before enabling interviews
KI-08	Unused _render_mermaid, _render_graphviz and scene_renderer pass model output to subprocesses	No caller today	Delete
KI-09	Each worker runs its own pipeline process pool; p95 shown per worker	Capacity planning	Size PIPELINE_WORKERS for 4 workers
KI-10	Outbox rows hold one-time links until sent	Short-lived sensitive data at rest	Owner to confirm (BACKEND-034 trade-off)
KI-11	Compiled files of about 30 earlier integration modules (2 Nov) exist without source	Those historical tests cannot be re-run; current suite covers their areas	Restore from backup if available; not counted in this report
KI-12	ESLint: 8 react-hooks dependency warnings	Code quality only	Address in maintenance

10 Items not tested

Item	Reason	Mitigation
Paid AI, text-to-speech and voice provider calls	Cost; no paid calls were authorised	Fakes, stubs and timeout tests; check in staging
Production environment and data	Out of scope by policy	Production-mode checks run locally (section 7.2)
Real e-mail delivery	Log provider used	Outbox logic tested; send one real e-mail after configuration
Voice on restricted networks	Needs a TURN server	Owner action INFRA-026
GitHub-hosted CI runs of the changed workflows	Not pushed (owner instruction)	Workflows statically checked; watch the first CI run
Load test with 4 workers at production scale	Only a live 4-worker health check and report timings were run	Run a load test in staging before peak use
User acceptance testing	Needs real users	Owner and client (section 11)
DPDP consent, retention and erasure	Legal and business decision	Owner action INFRA-022

11 Owner actions before go-live

#	Action	Ref.
1	Rotate every secret that appears in git history (JWT secret, provider keys, LiveKit pair, seed password), then rewrite history or treat the old values as burned	AUTH-009, INFRA-005, SECA-011, QA-006
2	Keep ENABLE_BOOTSTRAP off in production; set SEED_SUPERADMIN_EMAIL to a real mailbox (the default is a public yopmail address)	SECB-008, AUTH-009
3	Backend: pip install -r requirements.txt (adds uharfbuzz for Tamil PDFs) and alembic upgrade head (to 0057)	BACKEND-026, BACKEND-031
4	Frontend: stop the development server, then npm ci and npm run warm (local packages are still Next 14)	SECA-012
5	If production media is not bucket projectk-media in ap-south-1, set CSP_MEDIA_ORIGINS (and CSP_CONNECT_ORIGINS for another LiveKit host), or videos will be blocked	SECB-009
6	GitHub secrets and variables: e-mail provider, BACKUP_DIR, BACKUP_S3_URI (runner needs s3:PutObject), ALERT_WEBHOOK_URL, REDIS_URL if not the stack's own	INFRA-004, INFRA-007, INFRA-021
7	nginx: real server_name values and certificate paths; decide whether the workflow deploys the file	INFRA-008
8	Provide a TURN server for voice on restricted college networks	INFRA-026
9	Decide DPDP consent text, retention periods and the erasure process	INFRA-022
10	Confirm the voice agent starts with a read-only filesystem on first deploy	SECA-014
11	Add Unpublish and the delete-refused message to user guides (chapters must be unpublished before deletion)	BACKEND-021
12	Commit the changes, record the commit hashes in section 1.3, and watch the first CI run	-
13	Run user acceptance testing with real users and sign this report	-

12 Conclusion

The release candidate passes its automated test suites. The exceptions are two accepted layout tests and ten skips, each explained. These suites total 4,227 automated executions: 2,810 backend, 405 frontend unit and 1,512 cross-browser E2E. Besides that, the release candidate went through a security assessment of about 117,000 generated API cases and 49 manual attack probes. Every security defect found in code is fixed and has a regression test. The remaining risk is mainly operational: secret rotation, production configuration, network infrastructure for voice, a legal decision on data retention, and user acceptance. With the section 11 actions done, the platform is ready for production deployment.

13 Sign-off

By signing, each party confirms they have reviewed this report and its companion volumes and accept the results, the known issues (section 9) and the owner actions (section 11).

Role	Name	Signature	Date	Decision
QA lead				
Engineering lead				
Product owner				
Client representative				

Appendix A Test inventory by suite

Suite ID	Description	Test files	Support files	Test cases	Executions	Source lines
BE-API	Backend unit, API and security tests	22	0	255	409	3,562
BE-INT	Backend integration tests (real PostgreSQL)	11	2	105	1,286	3,104
BE-VID	Video pipeline (edu_video) tests	37	0	499	602	6,398
BE-MCQ	Quiz (MCQ) tests	7	0	89	156	1,204
BE-VOI	Voice tutor (voice_qna) tests	11	0	214	357	3,004
FE-UNIT	Frontend unit tests (vitest)	38	1	373	373	2,312
FE-INFRA	Frontend infrastructure and configuration tests (vitest)	1	0	32	32	289
FE-E2E	End-to-end browser tests (Playwright)	11	3	352	1,512	1,489
SEC-PRB	Manual attack probes (security assessment, 6 Nov 2026)	3	6	49	49	729

E2E executions count each test once per browser project that runs it (352 on 4 desktop projects plus 52 on 2 tablet projects). SEC-PRB lists the 49 probe results; its source is the probe scripts.

Appendix B How to re-run the tests

Run from each repository root. Database names must end in *_test*. Credentials come from the environment.

Purpose	Command

Backend, full suite (WSL)	`set -a; . ./.env; set +a`
	`export INTEG_DB_NAME=quirri_final_test`
	`python -m pytest tests -q`

Backend, integration only	`python -m pytest tests/integration -q`
Backend, skip reasons	`python -m pytest tests -q -rs`
Frontend unit + infra	`npx vitest run`
Frontend lint and audit	`npm run lint` `npm audit`
E2E, all projects	`E2E_PASSWORD=... npx playwright test` `(user e-mails in the E2E_* variables; see e2e/roles.js)`
E2E, one project	`npx playwright test --project=webkit`
Migration head	`alembic heads # expect: 0057 (head)`

Appendix C Evidence locations

Evidence	Location
Issue register	docs/audit/ISSUE_REGISTER.md (frontend repository)
SAST and supply chain raw output	docs/audit/evidence/security/sast/
DAST (ZAP reports, Schemathesis, header checks)	docs/audit/evidence/security/dast/
Attack probe scripts and results	docs/audit/evidence/security/attack/
Next.js 15 upgrade results and screenshots	docs/audit/evidence/next15/
Earlier baselines (browser, coverage, performance, privacy)	docs/audit/evidence/{browser,coverage,perf,privacy,sbom}/
Test source	Backend tests/; frontend src/**/*.test.js, scripts/infra.test.mjs, e2e/ (all reproduced in Volume 3)